Data Flow Diagram and Privacy: RAG-Diary

> Shows how data flows at context and process level, focusing on the path of personal data, the points where data crosses a trust boundary to a third party, and the protections in place.

> Thai version: DFD-PRIVACY.md

1. Document control

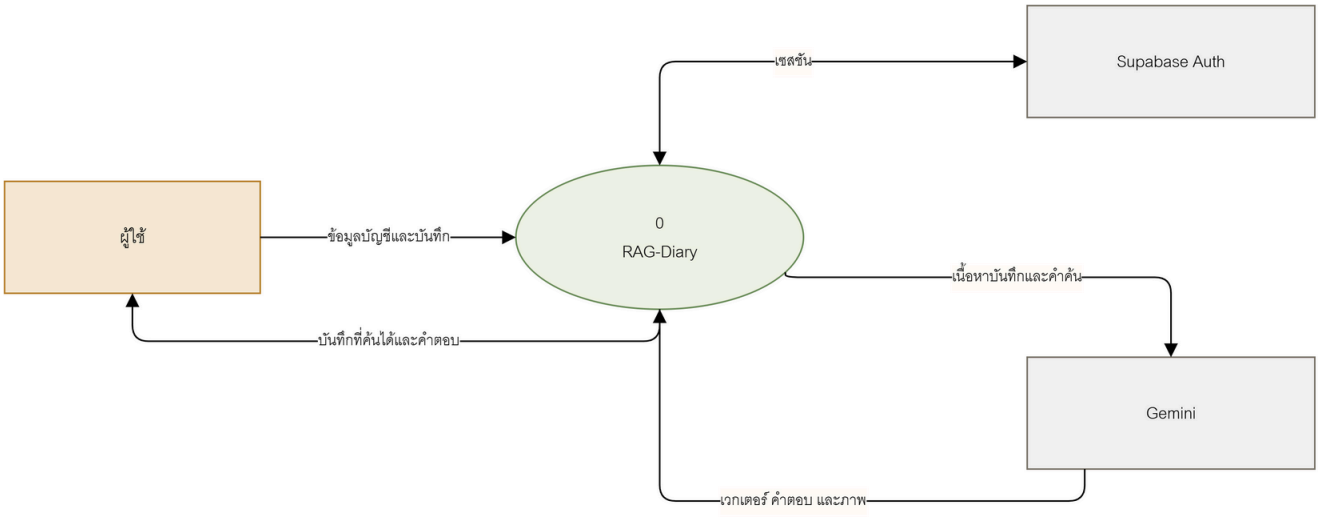
Item	Detail
Document	Data Flow Diagram and Privacy
Version	1.0
Prepared	15 October 2026
Author	Business Analyst / System Analyst (project owner)
Status	Reviewed, round 1 (25 October 2026)
Related documents	C4-ARCHITECTURE, DATA-MODEL, BUSINESS-RULES, NFR-SPEC

2. Purpose and scope

This document answers one question: where does user data flow, and where does sensitive data leave the boundary we control? It is the privacy review before go-live.

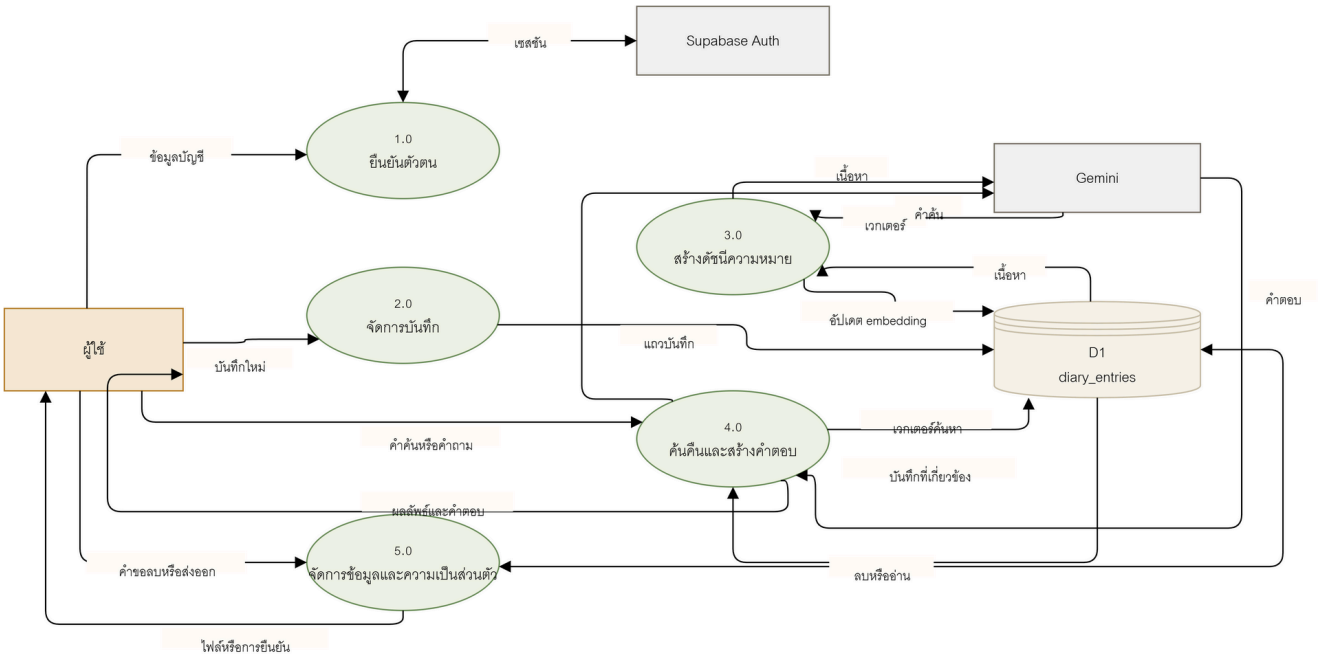
Scope: two levels of data flow diagram, trust boundaries, the personal data inventory, and the protections. Out of scope: data structure detail (in DATA-MODEL) and security measures (in NFR-SPEC).

3. DFD Level 0 (context diagram)



Personal data in the form of entry text and queries crosses the boundary to Google Gemini every time an index is built or an answer is generated. This is the point where notice and consent are required under NFR-03.

4. DFD Level 1



Element	Type	Description
1.0 Authenticate	Process	Handles registration, login and the session
2.0 Manage entries	Process	Create, read, edit and delete entries
3.0 Build the semantic index	Process	Turns text into a vector and updates the index
4.0 Retrieve and answer	Process	Searches by meaning and answers from context
5.0 Manage data and privacy	Process	Exports and deletes the user's data

Element	Type	Description
D1 diary_entries	Data store	Holds entries and vectors, with RLS
E2 Supabase Auth	External entity	The authentication provider
E3 Google Gemini	External entity	The provider for vectors and answers

5. Personal data inventory (PII)

Data	Stored in	Flows out to	Purpose	Protection
Email	Supabase Auth	Does not leave the authentication provider	Authenticate and identify the account	Managed by the authentication provider
Password	Supabase Auth	Does not leave	Authenticate	Stored as a one-way hash by the provider
Entry text	diary_entries	Google Gemini only when building an index or an answer	Build vectors and answers	RLS, consent, export and deletion
Vector (embedding)	diary_entries	Does not leave	Semantic retrieval	RLS
Tag	diary_entries	Travels with the text sent to Google Gemini	Group entries	RLS
Created time	diary_entries	Does not leave	Order entries	RLS
Session (httpOnly cookie)	The user's browser	Does not leave the system	Keep the user signed in	JavaScript cannot read it; Secure and SameSite=Lax

6. Trust boundary crossings

Point	Data crossing	Recipient	Measure	Related requirements
Build the semantic index	Entry text	Google Gemini	Notice and consent before use	NFR-03, BR-06
Retrieve and answer	The query, plus some entry text	Google Gemini	Only the signed-in user's index is used	FR-10, BR-05
Generate an image	The prompt derived from entries	Google Gemini	Comes directly from a user action	FR-12
Store data	All data	Supabase	Acts as a processor under the service agreement	NFR-02

7. Privacy protections in place

- Data isolation is enforced by RLS in the database; one user cannot reach another user's data (FR-15, BR-01).
- Users can export their own data (FR-13) and delete all of it (FR-14).
- AI answers are grounded only in the asking user's entries (BR-05).
- Notice and consent are requested before data goes out for processing (NFR-03, BR-06).

8. Observations and proposals

Topic	State	Proposal
Consent	Enforced on the client: notice and consent before every AI feature, withdrawable in settings	Record account-level consent evidence and review the wording with the data protection officer before publishing
Token storage	In httpOnly cookies that JavaScript cannot read	Set Secure and SameSite correctly in every environment
Sending data abroad	Text goes to an external provider	State the legal basis and tell the user clearly
Logging	No retention policy for logs that may hold sensitive data	Define a retention period and mask data in logs

9. References

Document	Relationship
C4-ARCHITECTURE	The components shown in the DFD
DATA-MODEL	Data stores and RLS policies
BUSINESS-RULES	The rules that shape the data flow
NFR-SPEC	The security and privacy measures